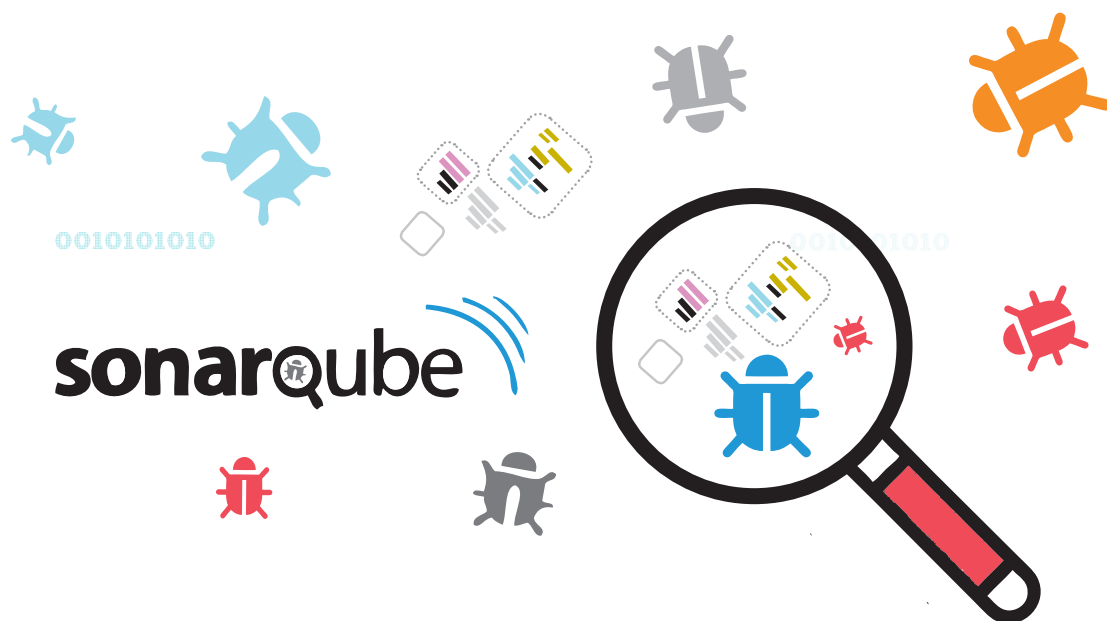


Static Application Security Testing (SAST) with SonarQube

SAST stands for static application security testing. It focuses on analysing the source code of an application to identify bugs, security vulnerabilities and code smells. The objective of SAST is to identify these issues early in the software development life cycle before they are identified and exploited in the production environment. SonarQube, a popular open source tool, can help with this.



SAST usually analyses an application's source code, configuration files, infrastructure configuration and build scripts to identify potential bugs and vulnerabilities. We don't need to execute the code to analyse it in SAST. This helps to? It helps to reduce the risk of security incidents and ensure that the application is secure before it is deployed in a production environment.

SAST helps to identify potential security risks such as:

- SQL injection attacks
- Cross-site scripting (XSS) attacks

SAST tools usually use a combination of rule-based analysis and code instrumentation to identify security risks and report them. SAST is often used with other security testing techniques popularly known as dynamic application security testing (DAST) and penetration testing (pen testing). We can also automate the process of code analysis to identify

bugs, vulnerabilities and code smells to deliver good quality applications with speed integrated in them.

SAST is typically managed and monitored by development teams. It can be integrated in the continuous integration and continuous delivery (CI/CD) pipeline to maintain process and stability, with quality gates integrated into it.

Overview of SonarQube

SonarQube is a very popular open source tool for continuous inspection of code quality. It provides an efficient way to identify and fix bugs, security vulnerabilities and code smells in analysed applications. SonarQube supports multiple programming languages such as Java, Python, Go, C#, and JavaScript. It is very easy to integrate SonarQube with popular CI/CD tools such as Jenkins, Azure DevOps, and GitLab. It also provides a centralised dashboard where you can get